

Reconstruct the attack — build a timeline & report

Session 10 – Incident response & log timeline

Exercise 10 · Session 10 lab · Estimated time: 90–120 min

Write your answers in the answer document `SKY2100_Exercise10_Answers.docx`. Last week you detected attacks in your logs. Today you respond like an incident handler: preserve the evidence, build a timestamp-ordered timeline of what happened, analyse the scope, practise one containment action, and write a short incident report. This ties S6–S10 together.

Caution: Work only on your own VM and logs. Treat the original logs as evidence: copy them and work on the copies; keep clocks in UTC.

1 Preserve the evidence

▷ Make read-only copies of the logs you collected in S9, so analysis cannot alter the originals:

```
mkdir -p ~/ir-evidence && cd ~/ir-evidence
sudo cp /var/log/auth.log /var/log/modsec_audit.log . # no auth.log? sudo
journalctl -u ssh > auth.log
sudo journalctl -u nginx > nginx.log
sudo fail2ban-client status sshd > fail2ban.txt
sudo chown "$USER": * && chmod 444 *
```

▷ Why copy and work on the evidence rather than investigating the live system directly? (one line)

AHA. The reason you work on copies is the same reason a timeline is hard: the moment you touch a live system you change it. Opening files updates timestamps, your own logins add log lines, and an attacker watching may notice. A read-only copy freezes the state so your account of events stays faithful, and in the cloud the equivalent first step is to snapshot the VM before you investigate. Keep one more thing in mind as you reconstruct what happened. Blocking an IP or disabling an account does not always stop access, because a session token already issued can stay valid until it expires. Containing an incident often means acting on identity, not just on the network.

2 Build the timeline

▷ From your copies, extract the security-relevant lines (failed logins, the ban, the WAF block) and order them by timestamp in the timeline table of the answer document — columns: time (UTC), source, event (actor / action / result). Normalise to UTC.

3 Analyse — RECIPE PICKS

▷ Apply a few RECIPE-PICKS questions to your incident and answer briefly:

- **Identity / IP** – which user/IP was the source of each action?
- **Permissions / blast radius** – what could that actor have reached if it had succeeded?
- **Public** – was anything exposed to the internet that should not have been?
- **Track** – any sign the attacker tried to pivot (e.g. from web attack to login)?

4 Contain

▷ Practise one containment action and record it (command + result):

```
sudo ufw deny from <attacker-ip>      # or:  sudo fail2ban-client set sshd
banip <ip>
sudo ufw status numbered
```

- ▷ Why are identity and management-plane containment higher priority than blocking a single IP? (one or two lines)

5 Write the incident report

- ▷ Write a one-page report with these sections:

1. **Summary** – what happened, in two sentences.
2. **Timeline** – your table from Section 2.
3. **Scope / impact** – what was affected; was anything successful?
4. **Actions taken** – detection, containment, recovery.
5. **Lessons learned** – what would you improve (detection sooner? a missing log?).

6 Cloud transfer: Microsoft Learn

- ▷ Read the concept units of “Security incident management in Microsoft Sentinel” (or the docs article “Microsoft Sentinel incident investigation in the Azure portal”) and note how a SIEM groups alerts into an incident with a timeline.

learn.microsoft.com/training/modules/incident-management-sentinel

learn.microsoft.com/azure/sentinel/incident-investigation

- ▷ Name the four phases of the IR lifecycle (NIST/CSA), and which phase “build a timeline” belongs to.

7 Azure reflection

- ▷ In the cloud, why is snapshotting a compromised VM the first forensic step, and what does a chain of custody protect?
- ▷ CSA warns a session token can outlive a ban (the AuthN/AuthZ gap). Why does that mean “I disabled the account” is not always “access stopped”?

8 Knowledge check

1. Distinguish an **event**, an **incident**, and a **breach**.
Hint: Any observable occurrence, versus one that breaks a security policy.
2. Name the four phases of the IR lifecycle in order.
Hint: Prepare; detect and analyse; contain, eradicate, recover; review.
3. Why is most of incident response done during **preparation**?
Hint: Under pressure there is no time to invent a plan — it must already exist.
4. What is a **runbook/playbook**, and how does SOAR relate to it?
Hint: Documented steps for one incident type; SOAR automates some of them.
5. Why must clocks be **synchronised** before you build a timeline?
Hint: Correlation needs aligned clocks, or the order of events scrambles.
6. What four things should you extract from each log line?
Hint: Time, actor, action, result — from every line.

7. What does **RECIPE PICKS** help a responder do?
Hint: A mnemonic for first priorities in a cloud management-plane incident.
8. Why **snapshot first**, before investigating a compromised VM?
Hint: Investigating a live system alters its state and can tip off the attacker.
9. What is a **chain of custody**, and why does it matter?
Hint: The documented record of who handled evidence and when — it keeps it admissible.
10. In cloud containment, why are IAM and the management plane the top priority?
Hint: The management plane can reach everything — the largest blast radius to contain.
11. Explain the **AuthN/AuthZ gap** and its effect on containment.
Hint: A session token can be accepted even after the account is disabled.
12. What happens in **post-incident analysis**, and where do its outputs go?
Hint: Capture the lessons — could it have been detected sooner, with what data?

Progress check: Discuss your answers in the group, then talk the teacher through them verbally at the next session only to track progress; nothing is handed in, signed or graded.

Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

Note: Model answers are indicative – accept equivalent reasoning. Multiple-choice answers are in **bold**.

Knowledge check

1. An **event** is any observable occurrence (may or may not be security-relevant). An **incident** is an event that violates a security policy and threatens operations. A **breach** is a successful penetration leading to unauthorised access or data extraction. All incidents are events; not all events are incidents (CSA p. 254).
2. **Preparation → Detection & Analysis → Containment, Eradication & Recovery → Post-Incident Analysis** (NIST SP 800-61 / CSA p. 254–255).
3. Under pressure there is no time to invent a plan. Preparation builds the team, roles, comms plan, responder access, baselines, runbooks and tested backups – so the response is deliberate, not improvised (CSA p. 255).
4. A **runbook/playbook** is the documented series of steps for a specific incident type. SOAR automates some of those steps (and stores the playbooks), but a manual fallback is needed in case SOAR fails (CSA p. 260).
5. Correlation across sources only works if timestamps align. A host with a wrong clock scrambles the order of events, breaking the narrative. Use UTC and synchronised time (NTP).
6. **Time**, **actor** (source IP / user), **action**, and **result** – from every line, so the timeline assembles itself.
7. **RECIPE PICKS** is a mnemonic for the first analysis priorities in a cloud management-plane incident (Resource, Events, Changes, Identity, Permissions, Entitlements, Public, IP, Caller, TracK, ForenSics). It focuses the responder and resolves a high percentage of incidents (CSA p. 265).
8. Investigating a live system alters timestamps, memory and state and can tip off the attacker. Snapshotting first preserves the VM's state so you analyse a faithful copy (CSA p. 266).
9. A **chain of custody** is the documented record of who handled evidence, when and how. It keeps evidence trustworthy and admissible, and proves it was not tampered with (CSA p. 266).
10. IAM and the management plane can reach everything – containing them limits the blast radius fastest. Blocking a single IP only stops one path; the attacker may hold credentials or tokens to get back in (CSA p. 267).
11. Federated identity separates authentication (IdP) from authorisation (relying party). A session token may be accepted until its TTL expires even after the account is disabled, so containment may require action on both sides (deny policies, accept only newer tokens) (CSA p. 267).
12. **Post-incident analysis** captures lessons learned (could it have been detected sooner? what data would have helped? does the process need to change?) and shares them. Its outputs feed back into preparation, closing the lifecycle loop (CSA p. 255).

Lab checkpoints

- **Preserve:** students should copy logs to a working folder and set them read-only, then work on copies. The point: logs are evidence; investigating the live system alters it (CSA p. 266).
- **Timeline:** a correct table has 4+ rows in UTC order, e.g. failed SSH logins (auth.log) → fail2ban ban → WAF block (ModSecurity, a 941xxx XSS rule) → 403 in the access log. Each row should name time, source and actor/action/result.

- **RECIPE PICKS:** identity/IP of each action; the (non-)blast-radius since both attacks were blocked; whether anything was public; and whether the attacker tried to pivot. Conclusion: no successful compromise – but provable.
- **Containment:** a UFW deny or fail2ban ban of the attacker IP is acceptable. The teaching point: blocking an IP is easy but lowest-leverage; identity/management-plane containment matters more in a real incident (CSA p. 267).
- **Report:** the one-page report is the key deliverable – summary, timeline, scope/impact, actions, lessons learned. Reward a clear timeline and concrete, honest lessons.

Cloud transfer & reflection

- **IR lifecycle:** Preparation; Detection & Analysis; Containment, Eradication & Recovery; Post-Incident Analysis. “Build a timeline of the attack” is part of **Detection & Analysis** (CSA p. 255).
- **Snapshot & chain of custody:** snapshotting preserves the VM’s state immediately, before investigation or containment changes it (CSA p. 266); the chain of custody documents who handled the evidence so it stays trustworthy and admissible.
- **AuthN/AuthZ gap:** a still-valid session token can be accepted until its TTL expires even after the account is disabled, so disabling the account does not instantly stop access – you may also need deny policies or token-issuance conditions at the relying party (CSA p. 267).

References

CSA Security Guidance v5, **Domain 11: Incident Response & Resilience** (p. 253–267, verified): event/incident/breach (p. 254), IR lifecycle phases (p. 254–255), preparation and “build a timeline” (p. 255), runbooks & playbooks (p. 260), RECIPE PICKS (p. 265), cloud forensics, snapshots & chain of custody (p. 265–266), container/serverless forensics (p. 266), IAM/management-plane & network containment and the AuthN/AuthZ gap (p. 267). Based on the CSA Cloud Incident Response Framework and **NIST SP 800-61 Rev. 2**. Comer, *The Cloud Computing Book*, Ch. 17.8 – security analytics (p. 239, recap). MS Learn: Security incident management in Microsoft Sentinel and the docs article Microsoft Sentinel incident investigation in the Azure portal (verified, August 2026).